



Raport dla klienta

Badanie bezpieczeństwa sieci od środka

5

Wykryte urządzenia

10

Otwarte porty

14

Ustalenia wymagające działania

5

Luki w pokryciu badania

Sonda

Sonda demonstracyjna

Identyfikator badania

PROBKA-0000-0000-0000-DEMO

Data wykonania badania

2026-09-18 09:12:44

Przebieg badania

zakończone

Adres sondy w badanej sieci

192.0.2.250

Raport odebrany

2026-10-04 15:10:55 UTC

Najwyższe stwierdzone ryzyko:

Krytyczne

Najbardziej narażone urządzenia: 192.0.2.30 (8 ustaleń), 192.0.2.20 (2 ustalenia), 192.0.2.1 (1 ustalenie)

1. Podsumowanie badania

Ocena ryzyka wynikająca z całości badania.

Badanie objęło pięć urządzeń w sieci, z których cztery odpowiedziały na skanowanie. Wykryto dziesięć otwartych portów i czternaście ustaleń wymagających działania, w tym dwa o wadze krytycznej. Oba krytyczne problemy dotyczą tego samego serwera 192.0.2.30 i są poważne: jeden pozwala odczytać dane, które powinny być szyfrowane, a drugi oznacza potwierdzoną możliwość zdalnego przejęcia kontroli nad bazą danych.

Sieć wymaga działań naprawczych i nie należy odkładać ich w czasie. Sytuację pogarsza fakt, że część badań nie odbyła się wcale — nie wiemy, co znajduje się na urządzeniu 192.0.2.40 i w sieciach bezprzewodowych. Tych obszarów nie można uznać za bezpieczne, ponieważ po prostu ich nie sprawdzono.

2. Ustalenia według wagi

Wszystko, co badanie wykazało, zebrane w jednym miejscu i uszeregowane od najpoważniejszego. Wagi wynikają z tego, co stwierdziły testy - ustalenie, którego test nie zdołał potwierdzić, jest oceniane niżej niż potwierdzone.

2

Krytyczne

5

Wysokie

7

Średnie

0

Informacyjne

WAGA	GDZIE	USTALENIE
Krytyczne	192.0.2.30 ssl-poodle · port 8443	SSL POODLE information leak CVE-2014-3566
Krytyczne	192.0.2.30 PostgreSQL	Potwierdzone zdalne wykonanie kodu na bazie danych (RCE) Sonda wykonała polecenie systemowe przez usługę bazy danych.
Wysokie	192.0.2.30 http-slowloris-check · port 8443	Slowloris DOS attack CVE-2007-6750
Wysokie	192.0.2.30 MySQL	Konto bazy danych bez hasła root
Wysokie	192.0.2.30 MySQL	Dane wrażliwe dostępne w bazie danych PESEL w crm.klienci; KARTA KREDYTOWA w crm.platnosci
Wysokie	192.0.2.20 23/TCP	Telnet dostępny w sieci Protokół przesyła hasła otwartym tekstem.
Wysokie	cała sieć	Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.
Średnie	192.0.2.30	Serwer WWW ujawnił ścieżki wymagające weryfikacji Wykryte podczas fuzzingu katalogów; część może być fałszywa - wymaga ręcznego potwierdzenia. https://192.0.2.30:8443/.git/config , https://192.0.2.30:8443/backup.sql , https://192.0.2.30:8443/phpinfo.php
Średnie	192.0.2.20 port 80	Panel kamery dostępny po nieszyfrowanym HTTP Wymuś HTTPS i ogranicz dostęp do sieci zarządzającej.
Średnie	192.0.2.1 port 53	Znane podatności w dnsmasq 2.80 (3 CVE, najwyższy CVSS 8.1) CVE-2021-3448, CVE-2020-25681, CVE-2020-25684 Dopasowanie po numerze wersji - wymaga potwierdzenia, czy podatny kod jest faktycznie używany.
Średnie	192.0.2.10 445/TCP	Udostępnianie plików SMB dostępny w sieci Dostęp do plików i klasyczny cel ataków w sieci lokalnej.
Średnie	192.0.2.30 3306/TCP	Baza danych MySQL dostępny w sieci Baza danych nasłuchująca w sieci.

WAGA	GDZIE	USTALENIE
Średnie	192.0.2.30 502/TCP	Modbus dostępny w sieci
Średnie	cała sieć	Porty przepuszczane na zewnątrz: 23, 445, 3389

Luki w pokryciu badania (5)

Poniższe testy nie dostarczyły wyniku. Tych obszarów badanie nie sprawdziło, więc nie można ich uznać ani za bezpieczne, ani za zagrożone.

- 192.0.2.40 — Skanowanie portów: test nie powiódł się na tym urządzeniu
- Sieci bezprzewodowe: test zablokowany przez zakres lub politykę badania
- Zatrutowanie rozgłoszeń — sonda nie przekazała wyniku
- Wycieki z katalogu LDAP — test nie wykonał się
- Bezpieczeństwo sieci bezprzewodowej — Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.

Najpoważniejsze są dwa ustalenia na serwerze 192.0.2.30. Na porcie 8443 wykryto podatność SSL POODLE — pozwala ona niepowołanej osobie odtworzyć fragmenty informacji przesyłanych w połączeniu, które powinno być szyfrowane. Drugie, jeszcze groźniejsze, dotyczy bazy danych PostgreSQL: sonda potwierdziła, że przez usługę bazy udało się zdalnie wykonać polecenie systemowe na serwerze. Oznacza to realną możliwość przejęcia kontroli nad maszyną.

Wśród ustaleń o wadze wysokiej znalazły się: podatność na atak typu Slowloris (192.0.2.30, port 8443), która może doprowadzić do niedostępności usługi; konto bazy MySQL bez hasła (192.0.2.30), co pozwala wejść do bazy bez żadnych danych logowania; oraz dane wrażliwe w tej samej bazie — numery PESEL klientów i dane kart kredytowych. Osobno odnotowano Telnet na 192.0.2.20 (port 23), który przesyła hasła jawnym tekstem, oraz brak blokady Gratuitous ARP, co pozwala przechwycić i podsłuchać ruch w sieci.

Ustalenia o wadze średniej obejmują m.in. ujawnione przez serwer WWW ścieżki wymagające weryfikacji, panel kamery dostępny po nieszyfrowanym HTTP, znane podatności w używanej wersji dnsmasq, dostępny w sieci udział plików SMB, wystawioną bazę MySQL oraz protokół Modbus na 192.0.2.30.

Należy wyraźnie zaznaczyć, że części badań nie udało się przeprowadzić: skanowanie urządzenia 192.0.2.40 nie powiodło się, nie zbadano sieci bezprzewodowych, nie sprawdzono zatrutowania rozgłoszeń ani wycieków z katalogu LDAP. Te obszary pozostają nieznane.

3. Wykryte urządzenia

Przegląd segmentu sieci i lista wszystkich urządzeń, które się w nim odezwały. Urządzenie, które odpowiedziało przy wykrywaniu, ale zamilkło przy skanowaniu portów, jest odnotowane osobno.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

ADRES	ADRES SPRZĘTOWY	PRODUCENT I MODEL	STAN
192.0.2.1	02:00:5e:00:53:01	Acme Networks GW-200 Linux 4.x (router)	3 otwarte porty
192.0.2.10	02:00:5e:00:53:0a	NorthStore NAS-4B Linux (NAS)	2 otwarte porty
192.0.2.20	02:00:5e:00:53:14	Visinet IP-Cam 3 Embedded Linux	2 otwarte porty
192.0.2.30	02:00:5e:00:53:1e	Generic Server Co. CentOS 7	3 otwarte porty
192.0.2.40	—	nieznany	skanowanie nieudane test przekroczył limit czasu

Wykrytych urządzeń: 5, odpowiedziało na skanowanie portów: 4.

W sieci wykryto pięć urządzeń, z czego cztery odpowiedziały na skanowanie: router 192.0.2.1, serwer plików 192.0.2.10, kamera 192.0.2.20 oraz serwer 192.0.2.30. Piąte urządzenie, 192.0.2.40, nie odpowiedziało — skanowanie przekroczyło limit czasu, więc nie wiemy, co się na nim znajduje ani jakie usługi udostępnia.

Cztery urządzenia mają co najmniej jeden otwarty port, co oznacza, że są aktywnie widoczne w sieci i oferują dostępne usługi. W praktyce każde z nich jest potencjalnym punktem wejścia dla osoby, która znalazłaby się w tej samej sieci.

4. Usługi dostępne w sieci

Sprawdzenie, co nasłuchuje na każdym wykrytym urządzeniu i w jakiej wersji. Wynik zostaje zachowany w pełnej postaci, nie w formie skrótu.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

URZĄDZENIE	PORT	USŁUGA	WERSJA ROZPOZNANA PRZEZ SONDĘ
192.0.2.1	53/TCP	domain	dnsmasq 2.80
192.0.2.1	80/TCP	http	lighttpd 1.4.59
192.0.2.1	443/TCP	https	lighttpd 1.4.59
192.0.2.10	445/TCP	microsoft-ds	Samba smbd 4.15.13
192.0.2.10	5000/TCP	http	Synology DSM httpd
192.0.2.20	23/TCP	telnet	nie ustalono
192.0.2.20	554/TCP	rtsp	nie ustalono
192.0.2.30	22/TCP	ssh	OpenSSH 7.4
192.0.2.30	3306/TCP	mysql	MySQL 5.7.38
192.0.2.30	8443/TCP	https	nie ustalono

Otwartych portów łącznie: 10, na 4 urządzeniach.

Na urządzeniach wystawiono dziesięć otwartych usług. Router udostępnia usługi DNS i WWW (porty 53, 80 i 443), serwer plików — udział sieciowy SMB oraz interfejs zarządzania (porty 445 i 5000), kamera — Telnet i strumień wideo (porty 23 i 554), a serwer 192.0.2.30 — zdalne logowanie, bazę MySQL i serwer WWW (porty 22, 3306 i 8443).

Największe ryzyko wiąże się z usługami, które nie powinny być dostępne w całej sieci: Telnet przesyła dane logowania jawnym tekstem, baza MySQL nasłuchuje w sieci, a udział SMB jest klasycznym celem ataków wewnątrz firmy. To wszystko zwiększa liczbę dróg, którymi ktoś niepowołany mógłby próbować wejść do systemów.

5. Pogłębione testy podatności

Testy uruchamiane przeciwko znalezionym usługom. Ustalenie oznaczone jako wymagające uwagi to takie, które nie zakończyło się zwykłym „nic nie znaleziono”.

URZĄDZENIE	TEST	USTALENIE
192.0.2.30	ssl-poodle	VULNERABLE: SSL POODLE information leak State: VULNERABLE IDs: CVE:CVE-2014-3566
192.0.2.30	http-slowloris-check	VULNERABLE: Slowloris DOS attack State: LIKELY VULNERABLE IDs: CVE:CVE-2007-6750

Ustaień łącznie: **3**, w tym wymagających uwagi: **2**, pozostałe 1 zakończyło się wynikiem czystym.

Bazy danych i aplikacje webowe

WAGA	GDZIE	USTALENIE
Krytyczne	192.0.2.30	Potwierdzone zdalne wykonanie kodu na bazie danych (RCE) Sonda wykonała polecenie systemowe przez usługę bazy danych.
Wysokie	192.0.2.30	Konto bazy danych bez hasła root
Wysokie	192.0.2.30	Dane wrażliwe dostępne w bazie danych PESEL w crm.klienci; KARTA KREDYTOWA w crm.platnosci
Średnie	192.0.2.30	Serwer WWW ujawnił ścieżki wymagające weryfikacji Wykryte podczas fuzzingu katalogów; część może być fałszywa - wymaga ręcznego potwierdzenia. https://192.0.2.30:8443/.git/config , https://192.0.2.30:8443/backup.sql , https://192.0.2.30:8443/phpinfo.php ...

Uruchomiono pogłębione testy przeciwko znalezionym usługom i przyniosły one trzy ustalenia, z których dwa wymagają uwagi. Na serwerze 192.0.2.30 potwierdzono podatność SSL POODLE (port 8443), która może prowadzić do wycieku informacji z szyfrowanego połączenia. Ten sam serwer wypadł też w teście na atak Slowloris jako prawdopodobnie podatny — taki atak może uczynić usługę niedostępną dla pracowników i klientów.

Pozostałe testy z tej grupy zakończyły się wynikiem czystym. Trzeba jednak pamiętać, że nie wszystkie zaplanowane testy się odbyły i część obszarów pozostaje niezbadana.

6. Ekspozycja i poświadczenia

Udziały plików dostępne bez uwierzytelnienia, ruch przestarzałych mechanizmów rozwiązywania nazw, pozostawione domyślne dane logowania oraz informacje wyciekające z katalogu firmowego do klientów anonimowych.

BADANY OBSZAR	WYNIK
Anonimowe sesje i udziały SMB	stan prawidłowy — nie stwierdzono podatności
Zatrutowanie rozgłoszeń	brak danych Sonda nie przekazała wyniku tego testu.
Skanowanie szablonami znanych podatności	stan prawidłowy — nie stwierdzono podatności
Domyślne poświadczenia	stan prawidłowy — nie stwierdzono podatności
Wycieki z katalogu LDAP	test nie wykonał się Test nie został uruchomiony, więc ten obszar pozostaje niesprawdzony.
Ryzyka infrastrukturalne	stan prawidłowy — nie stwierdzono podatności

Jeden moduł badania nie wykonał się poprawnie. Wyniku tych testów nie należy czytać jako „nic nie znaleziono” - one się nie odbyły.

Sprawdzono kilka typowych dróg wycieku danych. Anonimowe sesje i udziały SMB, skanowanie szablonami znanych podatności, domyślne poświadczenia oraz ryzyka infrastrukturalne — w tych obszarach nie stwierdzono podatności. To wynik czysty i oznacza stan prawidłowy w zbadanym zakresie.

Dwie kwestie nie zostały jednak sprawdzone. Zatrutowanie rozgłoszeń nie przyniosło wyniku, a test wycieków z katalogu LDAP w ogóle się nie wykonał. Tych obszarów nie można uznać za bezpieczne — po prostu nic o nich nie wiemy.

7. Protokoły przemysłowe ICS i OT

Punkty końcowe sterowania przemysłowego, takie jak CODESYS Runtime, EtherNet/IP czy IEC 60870-5-104, które zwykle nie mają czego szukać w sieci biurowej.

URZĄDZENIE	PORT	PROTOKÓŁ	STAN	OCENA SONDY
192.0.2.30	502/TCP	Modbus	open	WARNING

Punktów końcowych ICS/OT: 1. Stan open|filtered oznacza, że sonda nie mogła rozstrzygnąć, czy port jest otwarty, czy odfiltrowany.

W sieci znaleziono jeden punkt końcowy protokołów przemysłowych: na serwerze 192.0.2.30 działa protokół Modbus na porcie 502, który sonda oceniła jako wymagający uwagi. Modbus to protokół używany w sterowaniu urządzeniami przemysłowymi i zwykle nie ma wbudowanych zabezpieczeń dostępu.

Jego obecność na zwykłym serwerze z systemem CentOS 7, a nie na dedykowanym urządzeniu sterującym, jest nietypowa. Taki punkt końcowy powinien znajdować się w odizolowanej części sieci, a nie w zasięgu zwykłych urządzeń biurowych.

8. Diagnostyka sieci

Kondycja i konfiguracja sieci: opóźnienia, DNS, podatności na podsłuch i podszywanie się, zabezpieczenie portu dostępowego, ruch wychodzący oraz przepustowość. Poniżej znajdują się wyłącznie te testy, których wynik sonda przekazała.

Opóźnienia w sieci

Status	ok
Najniższe	0.4 ms
Średnie	0.8 ms
Najwyższe	1.9 ms

Kondycja DNS

Status	ok
Odpytany serwer	192.0.2.1
Czas odpowiedzi	12 ms

Podatność na podsłuch (MITM)

Status	ok
▲ Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.	
Assessment	Przełącznik nie blokuje Gratuitous ARP - ruch w segmencie można przekierować.

Filtrowanie ruchu wychodzącego

Status	ok
Porty przepuszczane na zewnątrz	▲ 23, 445, 3389

Bezpieczeństwo sieci bezprzewodowej

Status	blocked
Reason	foreign_block
▲ Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.	
Przechwycone ramki EAPOL	0

Przepustowość łącza

Opóźnienie (ping)	18.4 ms
Pobieranie	184.2 Mbit/s
Wysyłanie	41.7 Mbit/s

Najbardziej obciążające urządzenia

ADRES	PAKIETY	RUCH ŁĄCZNIE	WYSŁANE	ODEBRANE
192.0.2.10	182340	136,3 MB	90000 pk · 76,3 MB	92340 pk · 60,0 MB
192.0.2.1	90120	17,5 MB	45000 pk · 8,6 MB	45120 pk · 9,0 MB

Kondycja sieci jest dobra pod względem szybkości i niezawodności: opóźnienia w sieci są niskie i stabilne, a serwer DNS odpowiada prawidłowo. Przepustowość łącza wypada poprawnie, a najbardziej obciążającym urządzeniem jest serwer plików 192.0.2.10.

Dwa testy wykazały jednak problemy. Sieć nie blokuje Gratuitous ARP, co pozwala przekierować i podsłuchać ruch w segmencie — ktoś w tej samej sieci mógłby przechwycić przesyłane dane. Dodatkowo na zewnątrz przepuszczane są porty 23, 445 i 3389, co otwiera drogi do wyprowadzenia ruchu z firmy. Badanie sieci bezprzewodowej nie odbyło się, więc nie wiemy, czy fale radiowe nie są dostępne z zewnątrz budynku.

9. Plan naprawy

Działania wynikające wyłącznie z ustaleń tego badania, uszeregowane od najpilniejszego.

Plan naprawy, od najpilniejszych działań:

1. **Natychmiast odciąć i zabezpieczyć bazę PostgreSQL na 192.0.2.30** — to potwierdzone zdalne wykonanie poleceń na serwerze i najwyższe ryzyko w całym badaniu.
2. **Zamknąć dostęp do bazy MySQL na 192.0.2.30 z sieci i ustawić hasło do konta root** — obecnie baza jest dostępna bez hasła.
3. **Zabezpieczyć dane klientów w bazie na 192.0.2.30** — numery PESEL i dane kart kredytowych są przechowywane w sposób, do którego można dotrzeć; wymagają pilnej ochrony.
4. **Usunąć podatność SSL POODLE i zabezpieczyć się przed atakiem Slowloris na porcie 8443 serwera 192.0.2.30** — jedno pozwala odczytać szyfrowane dane, drugie może wyłączyć usługę.
5. **Wyłączyć Telnet na kamerze 192.0.2.20** i zastąpić go połączeniem szyfrowanym — obecnie hasła przesyłane są jawnym tekstem.
6. **Włączyć blokadę Gratuitous ARP** — bez niej ruch w sieci można przechwycić i podsłuchać.
7. **Ograniczyć filtrowanie ruchu wychodzącego** i zablokować porty 23, 445 i 3389, które obecnie wypuszczają ruch na zewnątrz.
8. **Zaplanować aktualizację dnsmasq na routerze 192.0.2.1** — używana wersja ma znane podatności; najpierw potwierdzić, czy podatny fragment kodu jest rzeczywiście używany.
9. **Ograniczyć dostęp do udziału SMB na 192.0.2.10** do niezbędnych urządzeń.
10. **Przenieść Modbus (port 502) z serwera 192.0.2.30 do odizolowanej części sieci** przeznaczonej dla urządzeń przemysłowych.
11. **Włączyć szyfrowane połączenie dla panelu kamery 192.0.2.20 i ograniczyć jego dostęp** do sieci zarządzającej.
12. **Ręcznie zweryfikować ścieżki ujawnione przez serwer WWW na 192.0.2.30** — część z nich może być fałszywa i wymaga potwierdzenia.
13. **Dokończyć badania, które się nie odbyły**: skanowanie urządzenia 192.0.2.40, badanie sieci bezprzewodowych, zatrutowania rozgłoszeń oraz wycieków z katalogu LDAP — bez nich nie wiadomo, czy te obszary są bezpieczne.

Ponowne przeprowadzenie audytu weryfikującego przy pomocy sprzętowego analizatora w celu technicznego potwierdzenia skuteczności wdrożonych zabezpieczeń.